

Response to Reviewers

ACIT 2026 — Paper #336

Title: Hybrid PQ-OPAQUE: Fixed-Round Post-Quantum Reinforcement of OPAQUE via ML-KEM-768

Track: Cyber Security

We thank both reviewers for their careful reading and constructive feedback. We are grateful to Reviewer #2 for the strong-accept recommendation, and we have used Reviewer #1's comments to substantially improve the presentation, the security argument, and the deployment analysis. **All four of Reviewer #1's suggestions have been addressed** in the revised manuscript. Below, each reviewer comment is quoted (in italics) and followed by our response; in the revised manuscript the principal changes are highlighted in blue.

Reviewer #1

Comment 1.

The article needs to be reformatted.

Response. We carried out a thorough editorial and structural revision:

- **Removed redundant/overlapping tables.** Several tables duplicated material already present in the prose or in other tables; their content was consolidated into the running text, removing float clutter while preserving every quantitative fact.
- **Repaired all cross-references** (see Comment 2): every remaining table and figure is now explicitly referenced from the text.
- **Added a legend to the PAKE-comparison table** (Table I) defining all abbreviations (Bal., Aug., Part., Passive, IC, ROM, UC).
- **Expanded all acronyms at first use** (OPRF, MAC, FFI, IKM, DDH).
- **Unified the role vocabulary** by stating the equivalence initiator = client / responder = server at first use.
- **Editorial cleanup:** removed an unused preamble package, made all reference DOIs consistently formatted and clickable, corrected two RFC titles to their official forms, and replaced a hard-coded section number with a symbolic cross-reference.

Comment 2.

The text lacks references to some figures and tables, specifically Tables 1, 6, 8, and 11; Figure 1.

Response. Thank you for catching this. In the revised manuscript **every figure and table is explicitly cross-referenced** from the body text, which we verified exhaustively. The previously uncited comparison/auxiliary tables were either given an explicit in-text reference or consolidated into prose where they duplicated existing material, so that no orphaned float remains. The former Figure 1 (message-flow diagram) is now a clean rendered figure and is referenced where the three-message flow is introduced.

Comment 3.

It is advisable to provide a correct computational proof of security in the post-quantum model.

Response. We added a new subsection, “*Computational Security Argument in the Post-Quantum Model*”, presenting a game-based argument that complements the symbolic analysis. Under (i) IND-CCA2 security of ML-KEM-768, (ii) a Gap-CDH assumption over Ristretto255, and (iii) modelling HKDF-Extract over HMAC-SHA-512 as a split-key PRF (in the sense of Giacon–Heuer–Poettering) in the (quantum) random-oracle model, the session key is indistinguishable from random, with the distinguishing advantage bounded by

$$\text{Adv}^{\text{ind}} \leq \min\{ \text{Adv}_{\text{GapCDH}}^{\text{Ristretto255}}, \text{Adv}_{\text{ML-KEM}}^{\text{IND-CCA2}} \} + \text{Adv}_{\text{HKDF}}^{\text{skPRF}}.$$

We give the corresponding concatenation-combiner reduction and read the quantum case in the QROM, noting that Grover search only halves the relevant symmetric margins. Consistent with the paper’s stated claim boundaries, we present this as a *scoped* reduction under explicit assumptions rather than a full universally composable proof, and we say so explicitly.

Comment 4.

The issues regarding the impact on scalability in large distributed systems have not been sufficiently addressed.

Response. We added a dedicated subsection, “*Scalability in Large Distributed Systems*”, which analyses:

- **Horizontal scaling:** because the construction preserves the fixed-round OPAQUE choreography and adds no round trip, stateless front ends and load balancers are unaffected and authentication shards per account record.
- **No persistent state growth:** the post-quantum material is ephemeral and session-scoped, so it does not enlarge the replicated server-side record.
- **The true scaling constraint:** memory-hard password hardening (a 256 MiB Argon2id profile), not the post-quantum layer, bounds concurrent authentications; this is identical to classical OPAQUE and is addressed by a dedicated authentication tier, admission control/rate limiting, and a device-class-tuned KSF profile.
- **Bandwidth:** the +2272-byte per-authentication payload scales linearly with the login rate and is negligible relative to application traffic, but is now budgeted explicitly.

In direct support of this analysis, the experimental evaluation is now reported on a **server-class Linux/Xeon platform** (two Intel Xeon E5-2650 v4, 24 cores / 48 threads), which is more representative of an authentication-server deployment than the previous single-laptop measurement; the benchmark tables and headline figures were updated accordingly and are internally consistent.

On the rating dimensions (presentation, research design, methods/results/conclusions): the changes above—cleaner formatting, the explicit claim-to-evidence mapping in the symbolic-verification summary table, the computational argument, fully traceable benchmark numbers, and the comparison of balanced and augmented PAKEs (Table I)—were made specifically to strengthen these aspects.

Reviewer #2

I recommend accepting the paper in its current form.

Response. We thank the reviewer for the positive assessment and the strong-accept recommendation. The revisions made in response to Reviewer #1 are additive and editorial; they preserve the logical structure, section organisation, and English quality that the reviewer found satisfactory, while strengthening the security argument and the deployment/scalability discussion.

Summary of Changes

1. New subsection: computational security argument in the post-quantum model, with an explicit advantage bound and reduction (Comment 3).
2. New subsection: scalability in large distributed systems (Comment 4).
3. All figures and tables are now cross-referenced; redundant tables consolidated into prose (Comments 1–2).
4. New comparison of balanced and augmented PAKEs (Table I) with a full abbreviation legend.
5. Experimental evaluation reported on a server-class Linux/Xeon platform; all benchmark numbers updated and made internally traceable.
6. Editorial: all acronyms expanded at first use; role terminology unified; reference titles corrected to their official forms and all DOIs made consistent and clickable; unused preamble package removed; section cross-reference made symbolic.

The manuscript remains within the page limit. We believe the revised version fully addresses the reviewers' comments, and we thank them again for helping us improve the paper.